

flaws and vulnerabilities. Also called ethical hacking.

Whitelist: A list of trusted entities.

Wipe: Removal of data from a device.

Wireless payment technology: The use of different core technologies to exchange payment credentials and authorization between the mobile device and the payment recipient. Examples include: near field communication, image based, carrier-based, mobile P2P, etc.

Appendix C: Schematic of Retail Payments

Access Channels & Payments Method

Retail payments can be categorized within two broad groups according to the access channel and the payment method. The access channel is used at the beginning of the transaction process and provides the user interface (e.g., a plastic card with a magnetic strip). The payment method includes the remaining parts of the payments process governed by applicable laws, regulations, and contracts.

ACCESS CHANNELS AND PAYMENT METHODS

NONCASH PAYMENT METHODS*(transaction, clearing & settlement processes)*

<u>ACCESS CHANNELS</u> (Front End)	ESTABLISHED: - Check - Credit card - ACH debit - ACH credit - ATM account debit - Wire transfers - Established C-B relationship	NEW: - Prepaid - Balance transfer (book entry) - Bank line of credit (new relationship)
ESTABLISHED: - Plastic Card - Paper Check - Telephone	(well known technologies initiate commonly known types of payments) - Credit card payments - Paper checks - PPD ACH debit - PPD ACH credit - PIN debit - Signature debit	- General purpose prepaid cards - Payroll cards - Closed network and gift Cards
NEW COMBINATIONS OF ESTABLISHED COMPONENTS:	- ACH debit card (e.g. Debitman) - ACH TEL - Micropayment Aggregator (e.g., BitPass, Peppercoin, Yaga, Check 21 Substitute Check)	
NEW: - Internet - Cell phone - Check Image - MICR Reader - Biometric Reader - RFID - Personal Data	(new technologies or networks access established payment method) - ACH POP - ACH ARC - ACH WEB - Check image presentment (not IRD) - Cell phone payment - Highway toll booths - Contactless card payments (debit or credit) - Charge to phone bill - Biometric authentication - License ID	- Proprietary balance transfer - Secured proprietary balance transfer - Proprietary balance transfer via cell phone - Prepaid wallet - Instant credit (e.g., Bill Me Later, e-Charge)

Figure 13

Payment methods that have the fewest changes from established methods are shown in the upper left quadrant above. The lower right quadrant includes emerging payment methods in terms of access channels and payment methods. The remaining two quadrants, upper right and lower left, are hybrids of new and established components. The left side of the matrix shows examples of access channels used to initiate payment

transactions, while the top of the matrix identifies general payment methods. The cells list a sample of the payment types that incorporate these various access and payment-method components. Retail payments may be effected using a variety of electronic networks in addition to the traditional cash and check processes. The electronic networks, which are discussed throughout this handbook, include the Automated Clearing House, card associations such as Visa, or MasterCard, and ATM networks.

Retail payment systems continue to evolve with advances in technology. These advances enable financial institutions to develop new products and services, to lower the barriers to business entry for smaller institutions, and to use "economies of scale."

Appendix D: Laws, Regulations, and Guidance

Laws

- 15 USC 1601: Truth in Lending Act (N/A)
- 12 USC 1861-1867(c): Bank Services Company Act (N/A)
- 12 USC 4001: Expedited Funds Availability Act (N/A)
- 12 USC 5001: Check Clearing for the 21st Century Act (N/A)
- 15 USC 1681m(e): Fair Credit Reporting Act (N/A)
- 15 USC 1693: Electronic Funds Transfer Act (N/A)
- 15 USC 6801 and 6805(b): Gramm-Leach-Bliley Act (N/A)
- 18 USC 1 (Pub. L. No. 107-56): USA Patriot Act (N/A)
- 31 USC 5311: Bank Secrecy Act (N/A)

Federal Financial Institutions Examination Council

- Authentication in an Internet Banking Environment (October 2005)
- Bank Secrecy Act/anti-Money Laundering InfoBase (N/A)
- Check 21 InfoBase (N/A)

Federal Reserve Board

- 12 CFR 210, Subparts A and B (Regulation J) (N/A)
- 12 CFR 205 (Regulation E) (N/A)
- 12 CFR 226, Truth in Lending (Regulation Z) (N/A)
- 12 CFR 229, Subparts A, B, and C (Regulation CC) (N/A)
- SR Letter 09-2: FFIEC Guidance Addressing Risk Management of Remote Deposit Capture Activities (January 14, 2009)
- Board of Governors of the Federal Reserve System Payments System Risk (PSR)

Policy (December 19, 2008)

- SR Letter 07-15: Release of Revised FFIEC Bank Secrecy Act/Anti-Money Laundering Examination Manual (August 24, 2007)
- SR Letter 05-19: Interagency Guidance on Authentication in an Internet Banking Environment (October 13, 2003)
- SR Letter 01-15: Safeguarding Customer Information (June 7, 2001)
- SR Letter 01-11: Identity Theft and Pretext Calling (April 26, 2001)
- SR Letter 00-17: FFIEC Guidance on the Risk Management of Outsourced Technology Services (November 30, 2000)
- SR Letter 00-04: Outsourcing of Information and Transaction Processing (February 29, 2000)
- SR Letter 93-64: Credit Card-related Merchant Activities (December 18, 1993)

Federal Deposit Insurance Corporation

- FIL 4-2009: Risk Management of Remote Deposit Capture (January 14, 2009)
- FIL 129-2008: New General Counsel's Opinion No. 8, Stored Value Cards and Other Nontraditional Access Mechanisms (November 13, 2008)
- FIL 127-2008: Guidance on Payment Processor Relationships (November 7, 2008)
- FIL 44-2008: Guidance on Managing Third-Party Risk (June 6, 2008)
- FIL 32-2007: Identity Theft - FDIC's Supervisory Policy on Identity Theft (April 11, 2007)
- Credit Card Activities Manual (March 2007)
- FFIEC Guidance Authentication in an Internet Banking Environment, FIL 103-2005 (October 2005)
- FIL 7-2005: Fair and Accurate Credit Transactions Act of 2003, Guidelines Requiring the Proper Disposal of Consumer Information (February 2, 2005)
- FIL 116-2004: Check Clearing for the 21st Century Act (October 27, 2004)
- FIL 39-2001: Identity Theft and Pretext Calling (May 9, 2001)
- FIL 79-98: Electronic Financial Services and Consumer Compliance (July 16, 1998)

National Credit Union Administration

- NCUA Letter to Credit Unions, 09-CU-01: Risk Management of Remote Deposit Capture (with Enclosure) (January 2009)
- NCUA Letter to Credit Unions, 07-CU-13: Supervisory Letter - Evaluation Third Party Relationships (December 2007)
- NCUA Corporate Credit Union Guidance Letter 07-04: Accounting for Future-Dated Automated Clearing House (ACH) Transactions (October 2007)
- NCUA Letter to Credit Unions 06-CU-14: Bank Secrecy ACT (BSA)/Anti-Money Laundering (AML) Manual Interagency Outreach (September 2006)
- NCUA Letter to Credit Unions 05-CU-18: Guidance on Authentication in Internet Banking Environment (November 2005)
- NCUA Letter to Credit Unions 05-CU-16: Bank Secrecy Act Compliance (October 2005)
- NCUA Regulatory Alert 05-RA-02: Suspicious Activity Reports on OFAC blocked transactions (January 2005)
- NCUA Regulatory Alert 04-RA-12: Check 21 Act (October 2004)
- NCUA Regulatory Alert 03-RA-07: Final Patriot Act Regulations on Customer (Member) Identification (May 2003)
- NCUA Letter to Credit Unions, 01-CU-09: Identity Theft and Pretext Calling (September 2001)
- NCUA Letter to Credit Unions, 01-CU-11: Electronic Data Security Overview (August 2001)
- NCUA Regulatory Alert 01-RA-08: Interim Final Rules Amending Regulations B, E, M, Z, and DD - Electronic Delivery of Required Disclosures (August 2001)
- NCUA Letter to Credit Unions, 00-CU-11: Risk Management of Outsourced Technology Services (with Enclosure) (December 2000)
- NCUA Regulatory Alert 99-RA-3: Pretext Phone Calling by Account Information Brokers (February 1999)

Office of the Comptroller of the Currency

- Office of the Comptroller of the Currency (OCC) Comptroller's Handbook: Depository Services (November 19, 2008)
- OCC Bulletin 2009-4: Remote Deposit Capture: Interagency Guidance (January 14, 2009)
- OCC Comptroller's Handbook: Truth in Lending (October 6, 2008)
- OCC Bulletin 2008-12: Payment Processors: Risk Management Guidance (April 24,

2008)

- OCC Bulletin 2006-39: Automated Clearing House Activities: Risk Management Guidance (September 1, 2006)
- OCC Bulletin 2006-06: Bank Secrecy Act/Anti-Money Laundering: Joint Statement on Sharing Suspicious Activity Reports with Controlling Companies (January 27, 2006)
- OCC Bulletin 2005-13: Response Programs for Unauthorized Access to Customer Information and Customer Notice: Final Guidance (April 14, 2005)
- OCC Advisory Letter 2004-6: Payroll Card Systems (May 14, 2004)
- OCC Bulletin 2003-01: Credit Card Lending, Account Management and Loss Allowance Guidance (January 8, 2003)
- OCC Comptroller's Handbook: Merchant Processing (December 2001)
- OCC Bulletin 2001-47: Third Party Relationships, Risk Management Principles (November 1, 2001)
- OCC Bulletin 2001-6: Expanded Guidance for Subprime Lending Programs (January 31, 2001)
- OCC Advisory Letter 2000-10: Payday Lending (November 27, 2000)
- OCC Advisory Letter 2000-9: Third-Party Risk (August 29, 2000)
- OCC Advisory Letter 2000-6: Audit and Internal Controls (July 23, 2000)
- OCC Bulletin 2000-20: FFIEC Uniform Retail Credit Classification and Account Management Policy (June 22, 2000)
- OCC Bulletin 2000-16: Risk Modeling, Model Validation (May 30, 2000)
- OCC Bulletin 2000-3: FFIEC Consumer Credit Reporting Practices (February 16, 2000)
- OCC Bulletin 99-15: Subprime Lending: Risks and Rewards (April 5, 1999)
- OCC Bulletin 99-10: Interagency Guidance on Subprime Lending (March 5, 1999)
- OCC Bulletin 98-3: Technology Risk Management: Guide for Bankers and Examiners (February 4, 1998)
- OCC Bulletin 97-24: Credit Scoring Models, Examiner Guidance (May 20, 1997)
- OCC Advisory Letter 96-7: Credit Card Pre-Approved Solicitations (September 26, 1996)

Office of Thrift Supervision

- 12 CFR Part 570: Interagency Guidelines Establishing Standards for Safeguarding Customer Information, Appendix B (N/A)
- RB 37-37: Electronic Fund Transfer Act (May 5, 2009)
- CEO Letter 291: Risk Management of Remote Deposit Capture (January 14, 2009)
- CEO Letter 273: Compliance with Truth in Savings and Electronic Transfer Act Rules: Government Accountability Office Report 08-281 (April 25, 2008)
- CEO Letter 228: Interagency Guidance on Authentication in an Internet Banking Environment (October 13, 2005)
- CEO Letter 214: Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice (March 30, 2005)
- RB 37-10: Check 21 (February 18, 2008)
- Thrift Bulletin 82a: Third Party Arrangements (September 1, 2004)
- CEO Letter 90: FFIEC Information Technology Examination Handbook- Audit Booklet, Electronic Banking Booklet (July 23, 1998)
- CEO Letter 113: Internal Controls (July 14, 1999)
- Examination Handbook: Section 218, Credit Card Lending (N/A)
- Thrift Activities Handbook: Section 340, Internal Control (December 2003)
- Thrift Activities Handbook: Section 341, Technology Risk Controls (January 2002)
- Thrift Activities Handbook: Section 580, Payment Systems Risk (January 1994)
- Examination Handbook: Section 1330, Electronic Funds Transfer Act (N/A)
- Examination Handbook: Section 1335, Expedited Funds Availability Act (N/A)
- Examination Handbook: Section 1336, Check 21 (N/A)
- Check Clearing for the 21st Century Compliance InfoBase, OTS Press Release 04-43 (October 2004)

Appendix E: Mobile Financial Services

AppE.1 Introduction

Mobile financial services (MFS) are the products and services that a financial institution provides to its customers through mobile devices.¹ The mobile channel² provides an opportunity for financial institutions of all sizes to increase customer access to financial services and decrease costs. Although the risks from traditional delivery channels for financial services continue to apply to MFS, the risk management strategies may differ. As with other technology-related risks, management should identify, measure, mitigate, and monitor the risks involved and be familiar with technologies that enable MFS.

AppE.1.a Purpose and Scope

This appendix focuses on risks associated with MFS and emphasizes an enterprise-wide risk management approach to the effective management and mitigation of those risks. This appendix also discusses the technologies used in the mobile channel and may be helpful to the board and management for the integration of MFS into the institution's risk management program. The risks and controls addressed in this appendix, however, are not exhaustive. Additionally, this appendix contains a set of work program objectives to help the examiner determine the inherent risk and adequacy of controls at an institution or third party providing MFS.

AppE.1.b Background

MFS involve the use of a mobile device to conduct banking transactions and to initiate retail payments. Customers' mobile transactions often emulate those initiated on traditional desktop computers; however, MFS can provide more convenient transaction execution capabilities, such as the initiation or acceptance of mobile payments. MFS can pose elevated risks related to device security, authentication, data security, application security, data transmission security, compliance, and third-party management. Customers are often less likely to activate security controls, virus protection, or personal firewall functionality on their mobile devices, and MFS often involve the use of third-party service providers. This appendix addresses the following:

- MFS technologies.
- Risk identification.
- Risk measurement.
- Risk mitigation.
- Monitoring and reporting.

¹ A mobile device is a portable computing and communications device with information-storage capability.

² The mobile channel refers to providing banking and other financial services through mobile devices.